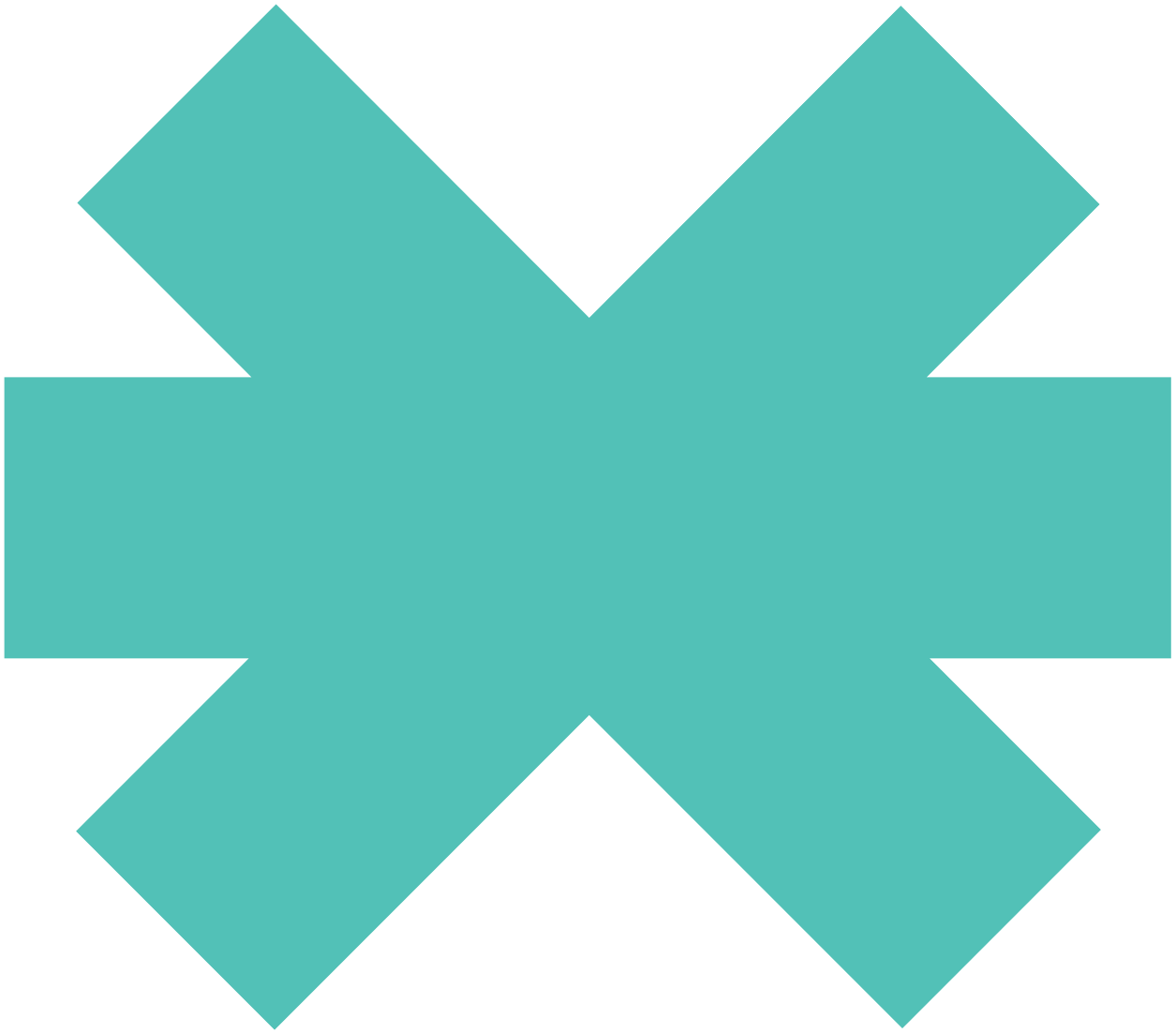


MÓDULO 1
Seguridad Informática
y Criptografía
Ciberseguridad

1

Fundamentos de la Ciberseguridad



1 Fundamentos de la Ciberseguridad

Sumario

1.1	Introducción a la ciberseguridad	10
1.2	Conceptos básicos de internet	12
1.3	La red: concepto y tipos	16
1.4	Seguridad informática y seguridad de la información	18
1.5	Tríada CIA	19
1.6	Conceptos de seguridad en <i>software</i>	24

1.1 Introducción a la ciberseguridad

Podemos definir la ciberseguridad como aquel conjunto de procedimientos dirigidos a proteger los sistemas informáticos y sus dispositivos, las redes y los datos de diferentes ataques, daños o accesos no autorizados con el objeto de salvaguardar la confidencialidad, la integridad y la disponibilidad de la información.

En un mundo cada vez más digitalizado, la ciberseguridad representa un elemento fundamental en nuestras vidas como consecuencia del incremento de amenazas cibernéticas como el *malware*, el *phishing* o el robo de datos, por citar solo algunas de las más frecuentes, de las que nos ocuparemos en detalle más adelante.

El origen de internet se remonta a la década de **1960**, cuando en los Estados Unidos se desarrolla un proyecto de investigación militar llamado **ARPANET**. Se trataba de una red de computadoras destinada a enviar datos militares y a conectar los principales grupos de estudio entre sí. Más adelante, en **1983** y a raíz de este proyecto inicial, surgiría lo que hoy conocemos como internet.

A lo largo de esas décadas, se estableció el **Protocolo de Control de Transmisión/Protocolo de Internet (TCP/IP)**, que es el conjunto de protocolos que permiten la comunicación de internet. Posteriormente, con la aparición de la **World Wide Web (WWW)** en la década de 1990, internet se populariza, pues se facilita el acceso a los datos y su intercambio a través de los navegadores, lo que transforma la comunicación, la sociedad y la forma de acceder a la información. Este crecimiento exponencial supone que, actualmente, en 2023, se contabilicen 5 160 millones de usuarios/as en todo el mundo.

Tal y como ha sucedido a lo largo de la historia a medida que se introducían distintos avances, el nacimiento de internet también ha supuesto una nueva vía de conflicto. En un principio, los enfrentamientos bélicos se llevaban a cabo por tierra, pero con la evolución de la ingeniería náutica y aeronáutica, el mar y el espacio aéreo se consolidaron como nuevos escenarios de contienda. Ahora, desde el surgimiento de internet, las redes y el ciberespacio representan nuevos contextos de confrontación, lo que puede implicar desde la suplantación de identidades hasta la vulneración de las estructuras críticas de un país, borrado de datos, etc.

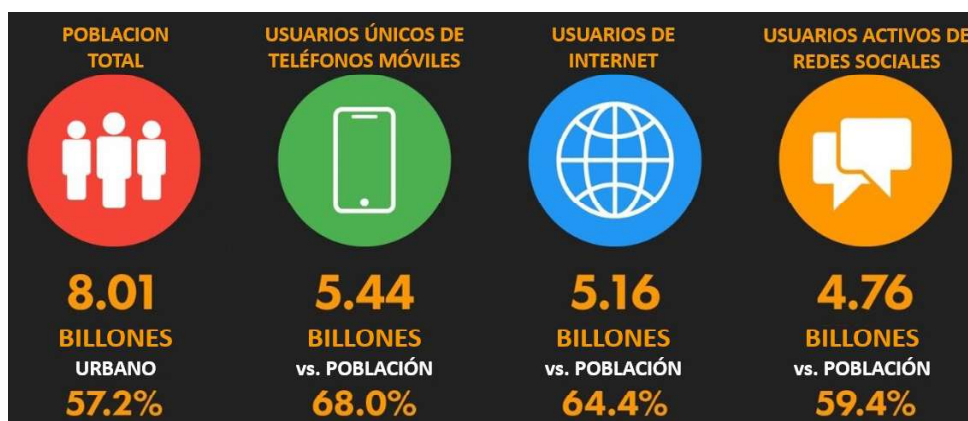


Figura 1. Gráfico de usuarios, dispositivos móviles y población

Considerando la imagen superior, podemos hacernos una idea de la cantidad de personas que utilizamos nuestros teléfonos para comunicarnos, una cifra que prácticamente se iguala al número de usuarios y usuarias de internet, ya que ambos canales se encuentran estrechamente relacionados. Paralelamente, el cómputo de personas que utilizan sus redes sociales para comunicarse con otras personas alcanza una cifra un poco inferior.

En base a esta nueva dimensión en las relaciones interpersonales, surge una nueva fuente de conflictos en todo el mundo, desde aquellos países que ya arrastraban conflictos previos hasta aquellos individuos que procuran el beneficio propio o, simplemente, causar daños. Cada día, se generan múltiples ataques de todo tipo y de todas las magnitudes a través de internet. Ahora bien, por suerte, solo un escaso porcentaje llegan a ser efectivos, ya que tanto las grandes compañías como las estructuras críticas permanecen protegidas frente a los ataques más habituales, si bien el riesgo cero no existe ni tampoco la seguridad absoluta.

A modo de ejemplo, en los siguientes enlaces podemos comprobar cómo en la actualidad se suceden constantes ataques entre diferentes países:

- <https://cybermap.kaspersky.com/> . Cybermap es una plataforma interactiva que muestra una representación visual en tiempo real de las amenazas cibernéticas en todo el mundo.
- <https://threatmap.checkpoint.com> . Como en el enlace anterior, también se ofrece un mapa interactivo de las amenazas cibernéticas en tiempo real, aunque este se centra específicamente en aquellas dirigidas a sitios web o a usuarios/as de internet.

Antes de adentrarnos en los fundamentos de la ciberseguridad, resulta necesario conocer una serie de conceptos importantes de cara a la correcta comprensión de las explicaciones que se proporcionarán a lo largo de los siguientes módulos, que presentan un carácter más técnico, práctico y complejo. Recurriendo a una frase del célebre filósofo Emmanuel Kant: *"La práctica sin teoría es ciega y la teoría sin práctica es estéril"*.

1.2 Conceptos básicos de internet

Para centrarnos en los fundamentos de la ciberseguridad, cuyos orígenes están ligados al desarrollo de internet, y comprender mejor su funcionamiento, debemos explicar, en primer lugar, aquellos conceptos básicos que engloba.

Tales conceptos resultarán fundamentales para abordar módulos posteriores como el de arquitectura de seguridad, el de técnicas de ciberataque y defensa e incluso de cara a la necesidad de recurrir a la criptografía para que los datos enviados solo puedan ser leídos por el emisor y el receptor elegido. Veamos, pues, los conceptos más importantes asociados a internet:

- **IP (Internet Protocol).** Se trata de un conjunto de reglas y protocolos que permiten la comunicación de datos digitales entre diferentes dispositivos conectados a una red y cuya función principal es el uso bidireccional de origen y destino para enviar dichos datos.
- **Dirección IP.** Representación numérica que identifica un dispositivo conectado a internet o una red local y que le permite transmitir información. Cuando un dispositivo se conecta a internet, dispone de una IP única que puede variar en cada conexión (IP dinámica) o ser fija (IP fija).
- **Red IP.** Rango de direcciones IP que comparten una característica común en una red determinada. La red IP se identifica mediante una dirección IP de red o una máscara de subred que define qué parte de la dirección IP se utiliza para detectar la red y qué parte se utiliza para identificar los dispositivos dentro de ella.
- **Dirección MAC (Media Access Control).** Se trata de un identificador único que cada fabricante asigna a la tarjeta de red de un dispositivo. Esta dirección física se encuentra vinculada a la capa de enlace de datos del modelo de referencia *Open Systems Interconnection* (OSI, que estudiaremos más adelante).
- **NAT (Network Address Translation).** Mecanismo empleado por los *routers* para traducir las IP entre conjuntos de direcciones incompatibles entre sí. El propósito de la NAT es que múltiples dispositivos compartan una única dirección IP pública en internet.

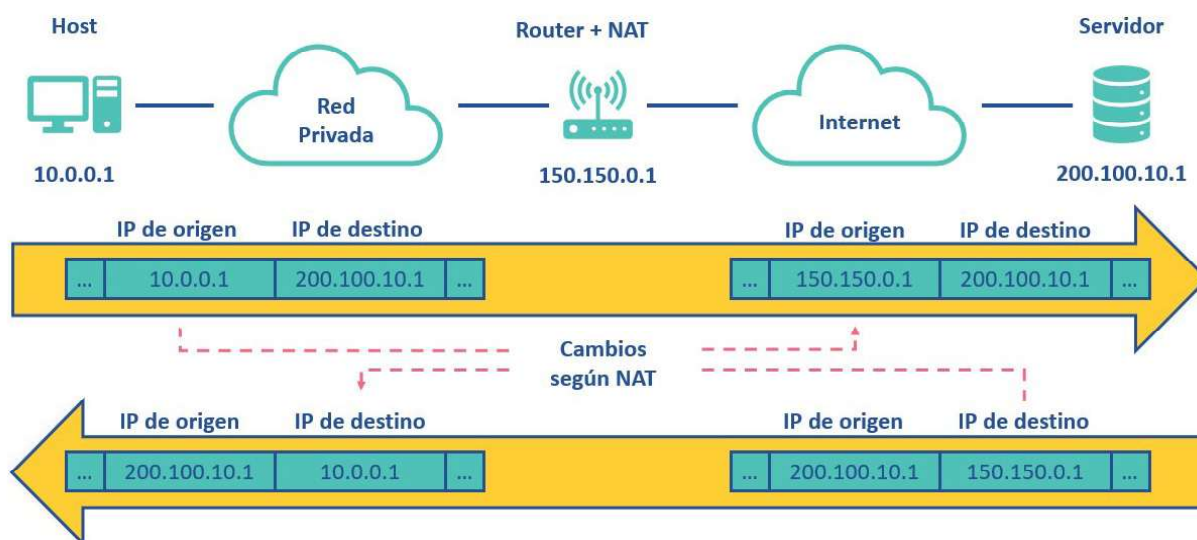


Figura 2

- **Host.** Cualquier dispositivo conectado a una red y capaz de enviar y recibir información, pudiendo tratarse de un ordenador, un servidor, un enrutador, etc. Cada *host* de la red posee una dirección IP única que lo identifica y permite que se comunique con otros *host* de esa red.
- **Paquete de datos.** También denominado paquete de red, representa una unidad de información transmitida a través de una red. Cuando se envían los datos, se dividen en paquetes o bloques que constan de los siguientes elementos:
 - **Encabezado.** Contiene las instrucciones sobre la información que transporta, como la dirección de origen y destino, el número de secuencia, etc.
 - **Carga útil.** Es la información que se entregará al receptor, pudiendo tratarse de un fragmento de un archivo, de un mensaje de correo electrónico, de una solicitud web, etc.
 - **Tráiler.** Indica al receptor que ha llegado al final del paquete y puede incluir la detección de errores, las sumas de comprobación o los datos de control.
- **Modelo TCP/IP.** Modelo para comunicaciones en redes que especifica cómo han de ser formateados, transmitidos y enrutados los datos. Comprende cuatro capas principales en las que profundizaremos en los siguientes módulos: la capa de **aplicación**, la capa de **transporte**, la capa de **internet** y la capa de **acceso a la red**.

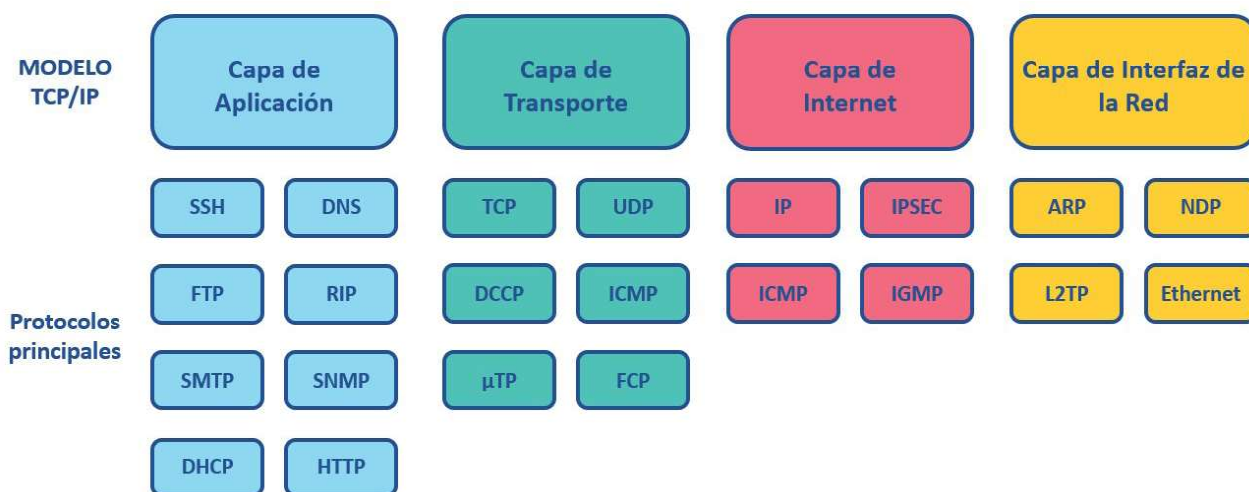


Figura 3. Modelo TCP/IP

Modelo OSI (*Open System Interconnection*). Estándar dirigido a interconectar sistemas de procedencia para que puedan intercambiar información. Este modelo, en el que también profundizaremos más adelante, consta de siete capas: la capa **física**, la capa **de enlace a datos**, la capa **de red**, la capa **de transporte**, la capa **de sesión**, la capa **de presentación** y la capa **de aplicación**.



Figura 4. Las siete capas del modelo OSI

- **Puerto.** Se trata de un número asociado a un protocolo específico que se utiliza para identificar aplicaciones y servicios en un dispositivo conectado a una red. En el modelo TCP/IP, la lista de posibles puertos para una aplicación abarca desde el 0 hasta el 65 535 y se divide en tres rangos:
- **Puertos conocidos.** Comprenden desde el puerto 0 hasta el 1023, ambos incluidos, y están reservados al sistema operativo; así, por ejemplo, el puerto 80 para HTTP, el puerto 22 para SSH, el puerto 443 para HTTPS, etc.
- **Puertos registrados.** Van del 1024 al 49151, están destinados a cualquier aplicación y se encuentran registrados en la **IANA** (Autoridad de Asignación de Números de Internet); así, por ejemplo, el puerto 27017 lo usa MongoDB, el servicio VNC emplea el puerto 5900, etc.
- **Puertos dinámicos o privados.** Son aquellos que se sitúan entre el 49152 y el 65535. Se trata de puertos temporales que el sistema operativo asigna a las aplicaciones cuando lo requieren y, una vez concluida la conexión, quedan libres de nuevo.
- **Socket.** Designa un concepto abstracto en base al cual dos procesos (posiblemente situados en computadoras distintas) pueden intercambiar cualquier flujo de datos, por lo general de manera fiable y ordenada. Además, se trata de una estructura de datos que permite que dos máquinas se comuniquen entre sí. Asimismo, el término *socket* se emplea para referirse a una interfaz de programación de aplicaciones (API) para la familia de protocolos de internet TCP/IP que suele proveer el sistema operativo.
- **DNS.** Acrónimo de *Domain Name Server*, utilizado tanto para dispositivos conectados a internet como para redes privadas. Básicamente, consiste en asociar un nombre a una dirección IP para que resulte más fácil de recordar.
- **Proxy.** Servidor que funciona como intermediario entre el dispositivo y los servidores a los que este accede de cara al envío de datos. Reúne las siguientes características:

- **Caché web.** Almacenamiento temporal de la información reportada por los servidores, permitiendo una respuesta más rápida.
- **Restricción de llamadas.** Bloquea las peticiones a los servicios internos o externos, es decir, expuestos a internet.
- **Balanceo de carga.** Consiste en redirigir el tráfico recibido hacia un servicio u otro según las condiciones seleccionadas, lo que contribuye a una distribución equitativa de la carga de tráfico.
- **Anonimato.** Evita que se conozca el destino de la petición, esto es, solo se sabe una dirección, pero el origen nunca conoce el destino interno de la red.
- **Acceso restringido.** Algunos *proxies* permiten el acceso a recursos o servicios que, de otro modo, permanecerían restringidos o bloqueados.

1.3 La red: concepto y tipos

El término red alude al **conjunto de sistemas informáticos independientes que se encuentran conectados entre sí**, lo que permite que puedan intercambiar datos. Hoy en día, las redes desempeñan un papel fundamental en la comunicación y en el intercambio de información, posibilitando la conexión de dispositivos y sistemas, así como la transferencia de datos y recursos.

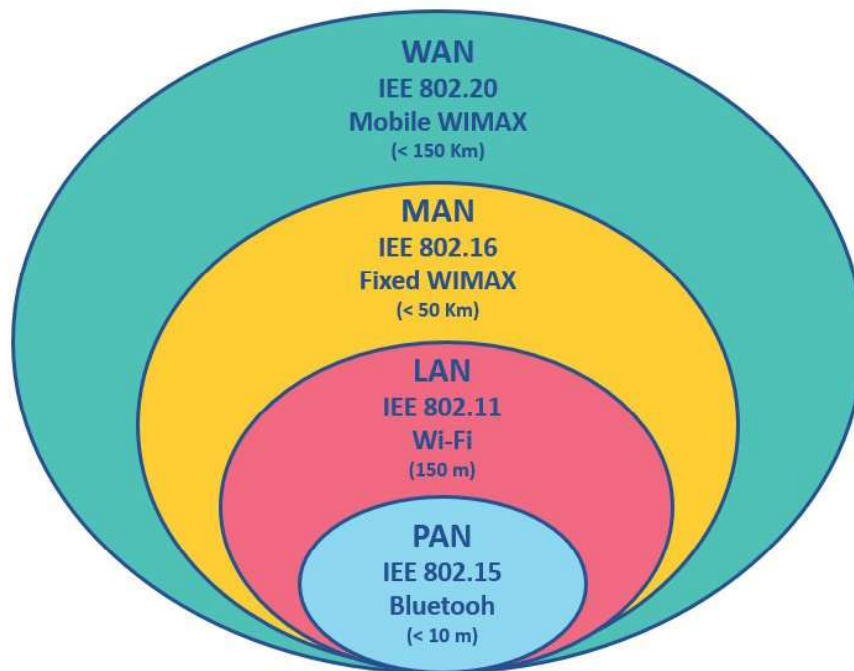


Figura 5

Podemos referirnos a diferentes tipos de redes que se utilizan en diversos entornos, si bien las más comunes e importantes son las siguientes:

- **PAN (Personal Area Network)**, también conocida como **red de área personal**. Se trata de una red de corto alcance (aproximadamente 10 metros) que, normalmente, está destinada al uso personal. Por lo general, presenta una distribución inalámbrica (por ejemplo, para cubrir una casa o una oficina pequeña), denominándose entonces como **WPAN (Wireless Personal Area Network)**.
- **LAN (Local Area Network)** o **área de red local**. Este tipo de red conecta al menos dos dispositivos, aunque puede comprender miles. Abarca un área geográfica limitada, como una oficina, un edificio o una universidad. Asimismo, suele utilizar tecnologías como Ethernet para conectar computadoras, servidores, impresoras y otros dispositivos en un entorno local.

También puede establecerse de forma inalámbrica, en cuyo caso se trataría de una red tipo **WLAN (Wireless Local Area Network)**, funcionando de la misma forma. Además, puede establecerse como **VLAN (Virtual LAN)**, lo que permite crear subredes independientes dentro de la misma red, segmentándola y dotándola de mayor seguridad.

- **MAN** (*Metropolitan Area Network*) o **red de área metropolitana**. Se trata de una red de telecomunicaciones entre distintas LAN ubicadas en una zona geográfica cercana, cubriendo un área de entre 50 y 60 km. Suelen recurrir a ellas instituciones educativas, organizaciones o proveedores de servicios.
- **WAN** (*Wide Area Nertwork*) o **red de área amplia**. Cubren áreas geográficas muy amplias que pueden comprender desde 100 km hasta miles. Están conformadas por redes LAN ilimitadas a las que recurren, por ejemplo, estructuras empresariales internacionales con sucursales en distintos puntos del mundo.

Por otro lado, podemos mencionar redes con una amplitud todavía mayor conocidas como **GAN** (*Global Area Neteork*), que son aquellas que emplean satélites y cables submarinos.

- **VPN** (*Virtual Private Network*) o **red privada virtual**. Establece una conexión segura y encriptada a través de una red pública como internet, permitiendo que los datos se transmitan de forma segura entre dispositivos o redes, como si estuviesen conectados directamente a una red privada.

1.4 Seguridad informática y seguridad de la información

Llegados a este punto, resulta necesario definir dos aspectos fundamentales de la ciberseguridad: la seguridad informática y la seguridad de la información. Ambos conceptos giran en torno a la protección de los sistemas informáticos y la información en el mundo digital, trabajando conjuntamente de cara a la prevención y respondiendo a las amenazas cibernéticas para garantizar la confidencialidad, la integridad y la disponibilidad de los activos digitales.

La **seguridad informática** se orienta a la **protección de los sistemas informáticos** (lo que incluye el *hardware*, el *software* y las redes) de las diferentes amenazas. Por tanto, implica la **implementación de medidas técnicas** como *firewalls*, sistemas de detección de intrusiones o antivirus, que describiremos detenidamente más adelante. Paralelamente, supone el **establecimiento de políticas y prácticas de seguridad** que permitan prevenir, detectar y responder a los posibles ataques.

La **seguridad de la información**, por su parte, se centra en la **protección de la información en sí misma**, al margen de los sistemas donde se encuentre almacenada, lo que conlleva la aplicación de medidas que permitan preservar su **confidencialidad, integridad y disponibilidad**, así como garantizar su **autenticidad** y prevenir que se **modifique o divulgue sin autorización**. En este sentido, se requieren **políticas** de gestión de accesos, clasificación de la información, copias de seguridad y encriptación.

1.5 Tríada CIA

Como hemos señalado en el punto anterior, el propósito de la seguridad de la información es mantener seguros los datos y la información de una organización y, para ello, se recurre a la tríada CIA.

La tríada CIA es un acrónimo que engloba los **principios de confidencialidad, integridad y disponibilidad**, que no solo se aplican a los sistemas, sino que también se pueden extrapolar a las aplicaciones, las bases de datos, los documentos o a cualquier otro elemento que involucre nuestra compañía o sistema y que resulte importante para este.

Por lo tanto, los equipos evalúan aplicaciones, datos y sistemas críticos para, posteriormente, tratar de reducir el riesgo mediante la implementación de controles de seguridad.



Figura 6

Tal y como trata de reflejar la imagen anterior, compaginar estas tres características resulta complicado, pues incrementar el nivel de una de ellas puede reducir significativamente el nivel de otra. En este sentido, es muy recomendable realizar un análisis de aquellos requisitos que reúne nuestra información para invertir más o menos en cada característica.

A continuación, profundizaremos en ellas:

- **Confidencialidad.** Dirigida a restringir el acceso a la información. Por tanto, cuanto más confidencial sea esta, menos personas deberían contar con acceso a ella. Para garantizar la confidencialidad, se recurre a diversas técnicas como la doble autenticación, el cifrado de los datos, los OTP (*Only Time Password*) temporales para el acceso, etc.



Figura 7. Fuente: Freepik.com

- **Integridad.** Implica que la información resulte fiable y que no haya sido modificada, en cuyo caso se requiere contar con la referencia exacta de aquello que se ha cambiado, así como de la persona o las personas que han efectuado el cambio, lo que ha de reflejarse en un registro de modificaciones de archivo. Para garantizar la integridad, se aplican técnicas como la de *hash* o función resumen, se realizan respaldos de seguridad o se evita que aquellas personas que accedan a la información cuenten con el rol de escritura, entre otras.

La integridad de datos evita:



Figura 8

- **Disponibilidad.** Supone garantizar la accesibilidad a aquellas personas que disponen del rol y del permiso adecuados. Por consiguiente, una mayor disponibilidad puede comprometer la confidencialidad o incluso la integridad, ya que la información podría ser modificada por más personas. Además, si se produjese una caída de servidores, este principio dejaría de cumplirse, ya que no se podría acceder a esa información temporalmente.

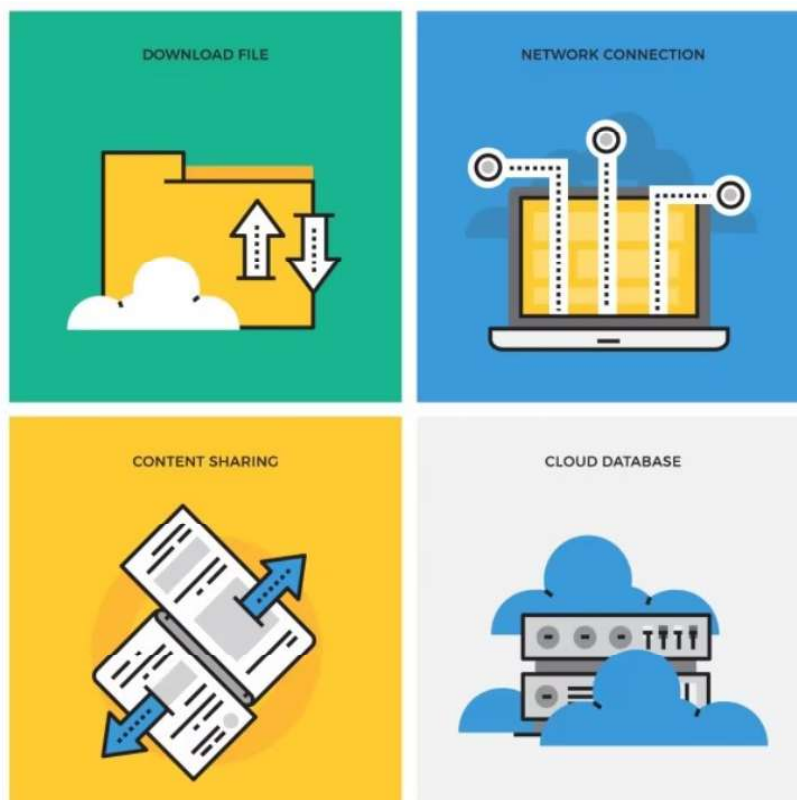


Figura 9. Fuente: Freepik.com

Otros aspectos que acompañan a la tríada CIA

Cabe destacar que, en los últimos años, han ido adquiriendo relevancia otros aspectos asociados a la seguridad de la información que también guardan relación con la tríada CIA:

- La **autenticidad**. El principio de autenticidad implica la garantía de que una entidad, ya sea una persona o un sistema, se trata, efectivamente, de quien dice ser. En otras palabras, se basa en la garantía del **origen legítimo de la transmisión**. Esta característica se encuentra muy ligada a la **integridad** y supone, por ejemplo, el uso de contraseñas o la autenticación de dos factores o certificados digitales.
- La **trazabilidad**. Permite rastrear las acciones, mensajes o contenidos hasta su origen, lo que exige registrar de forma adecuada los eventos relevantes (como los accesos, las modificaciones o las transacciones) para que se **pueda reconstruir y analizar el flujo de actividad** en caso de investigaciones, auditorías o incidentes de seguridad. En este sentido, se recurre a sellos de tiempo, ID de transacción y *logs* de eventos.
- **No repudio**. Principio orientado a **demostrar la participación de las partes**. Por tanto, procura evitar que un remitente o receptor de información niegue haber enviado o recibido un mensaje o bien haber realizado una acción específica mediante el uso de la firma o el certificado digital.

Principales sistemas de seguridad en internet

Denominamos sistema de seguridad al **conjunto de medidas y dispositivos destinados a proteger de los posibles riesgos y amenazas en un entorno digital**. Estos sistemas han sido diseñados para **detectar, prevenir y responder** a esos ataques o amenazas y presentan un **carácter dinámico**, pues van evolucionando a medida que surgen nuevas amenazas; por tanto, se actualizan permanentemente para garantizar una plena protección frente a los riesgos en línea.

Veamos los principales sistemas de seguridad en internet:

- **Firewall o cortafuegos**. Se trata de un componente crucial en el sistema operativo y se encarga de salvaguardar la red bloqueando accesos no autorizados y permitiendo únicamente el ingreso de aquellos que cuentan con los permisos pertinentes. Puede operar a nivel de *software* o de *hardware* y su función comprende tanto el filtrado de mensajes entrantes como salientes.

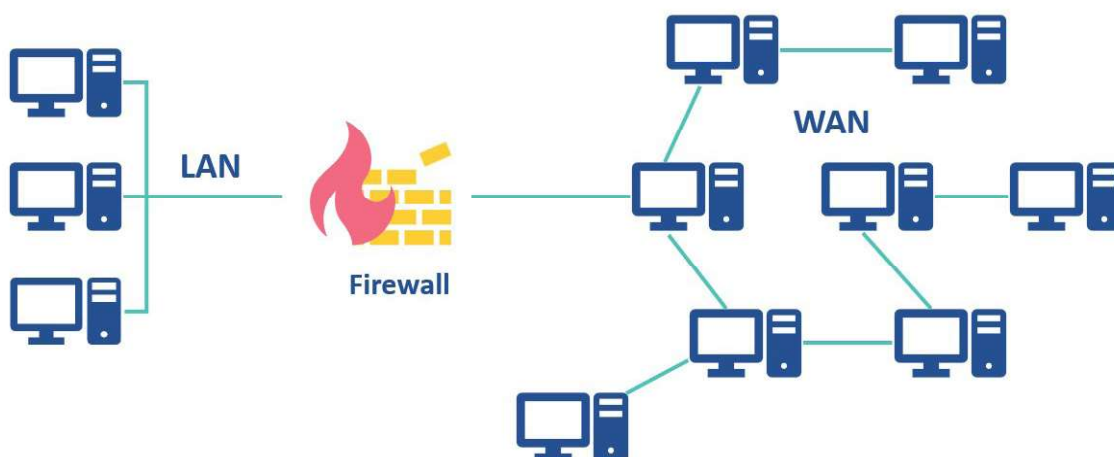


Figura 10

- **WAF** (*Web Application Firewall*). Es una solución de seguridad cuyo objetivo principal consiste en proteger contra aquellos ataques que reciben las aplicaciones web (entre ellos, un XSS, un SQLi o un DoS) creando un escudo entre internet y el servidor donde se encuentre desplegada la web.
- **IDS** (*Intrusion Detection System*). Sistema de detección de intrusos cuyo objetivo es identificar actividades sospechosas. Puede basarse en *host*, es decir, aplicarse a un *endpoint* en concreto, o bien supervisar toda una red. Adicionalmente, posee varios mecanismos de defensa que pueden utilizarse para mejorar la seguridad de nuestros sistemas (nivel de firma, anomalías o híbrida).

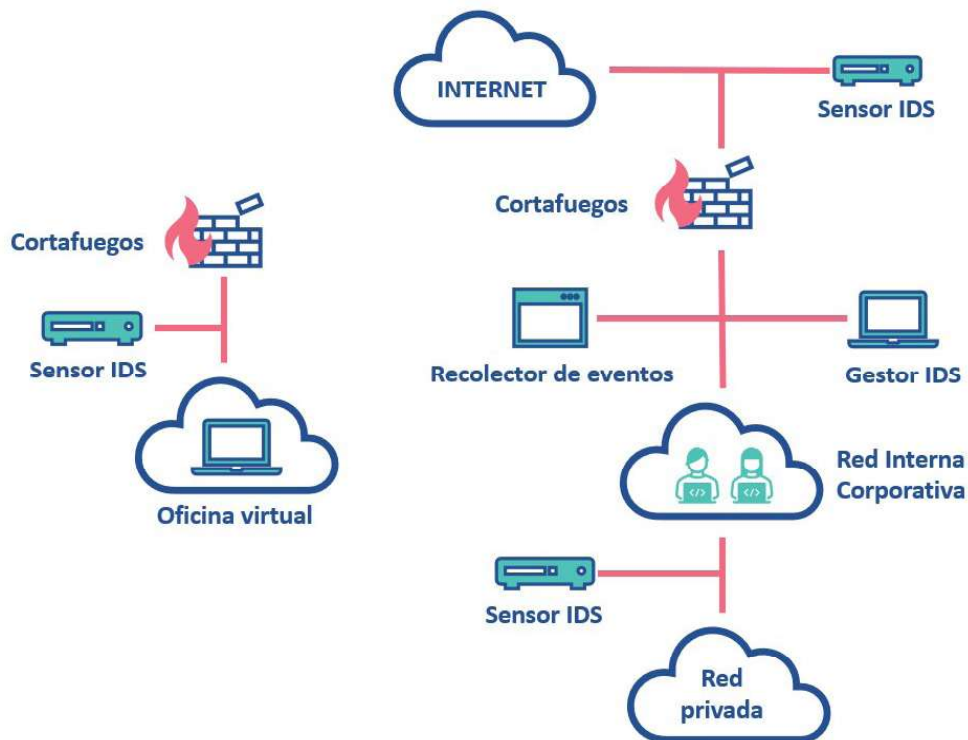


Figura 11. IDS

- **IPS** (*Intrusion Prevention System*). Se trata de sistemas de prevención contra intrusos y su principal objetivo es detectar aquellos atacantes que tratan de aprovecharse de una vulnerabilidad conocida. Uno de los mecanismos más conocidos es el *honeypot* que, básicamente, simula un entorno vulnerable para que el atacante crea que ha accedido y, de esta forma, poder investigarlo.

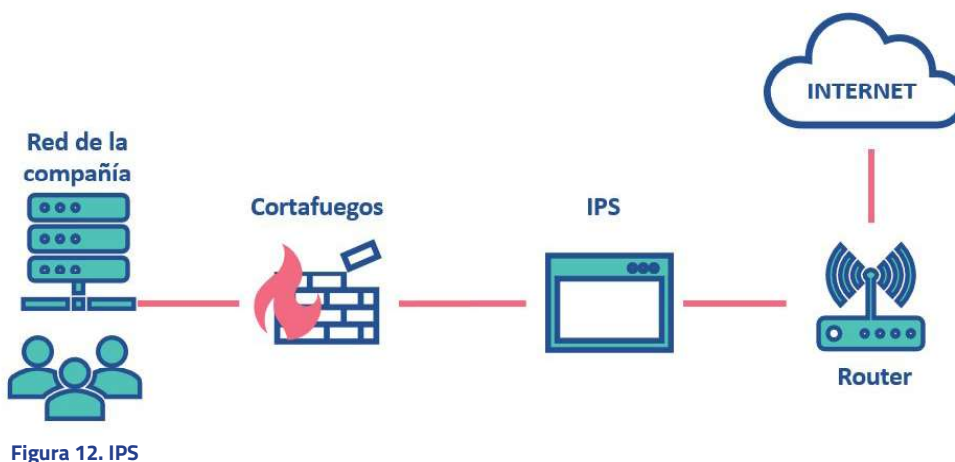


Figura 12. IPS

- **DMZ** (*Demilitarized Zone*). La DMZ o zona desmilitarizada es un mecanismo que suelen utilizar las empresas para proteger las conexiones de red. Se sitúa entre la zona por la que se accede a internet y la red interna de la organización y el objetivo es que los equipos o los servidores que se encuentran en ella no accedan a la red interna de la compañía.

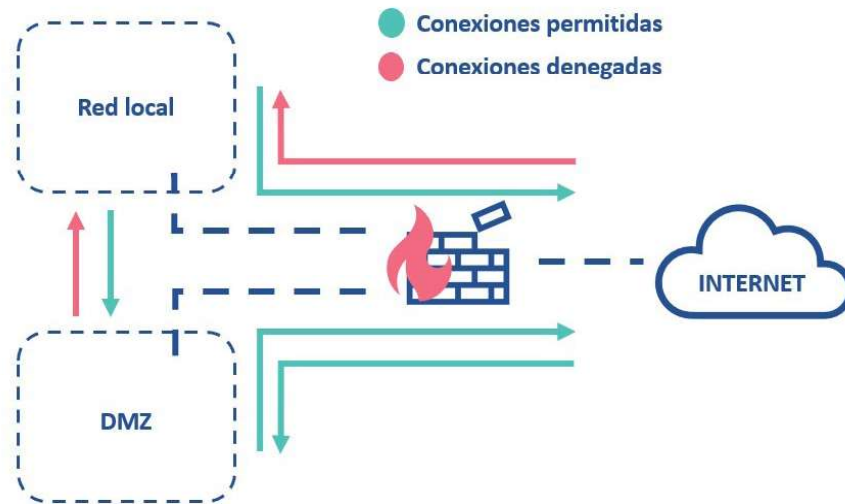


Figura 13. DMZ

En el siguiente módulo, profundizaremos en cada uno de estos sistemas para entender bien su funcionamiento y los diferentes subtipos que los integran.

1.6 Conceptos de seguridad en *software*

Uno de los conceptos más destacados en el ámbito de la seguridad es el *software* con el que se desarrollan los distintos servicios y aplicaciones, desde servicios bancarios o aplicaciones móviles hasta aquellos programas destinados a las redes sociales, ya que representan el principal objetivo de los atacantes. Partiendo de lo anterior, se deberían considerar tres grandes grupos a la hora de gestionar la seguridad de nuestro *software*, ya sea para una compañía multinacional o bien para un pequeño desarrollo a nivel usuario, pues como veremos a lo largo de este curso, la seguridad no es un proceso que se valore únicamente durante el desarrollo de *software*, sino que se encuentra embebida en todas las fases del proceso.

Teniendo en cuenta que, en este contexto, denominamos aplicación a todo servicio, aplicativo o incluso API que se esté desarrollando, ya sea a nivel interno o expuesto a internet, podemos referirnos a tres grandes grupos a la hora de gestionar su seguridad:

- **Código.** Resulta importante que el lenguaje de las aplicaciones que desarrolla una compañía se analice tanto estática como dinámicamente; en este sentido, disponemos de varias herramientas que evalúan su nivel de criticidad con el objeto de solventarlo antes de subirlas a producción. Entre los diversos procedimientos que nos permiten mejorar la seguridad de nuestro código, se encuentra SSDLC, que establece un ciclo de vida seguro de cara al desarrollo de nuestras aplicaciones.
- **Infraestructura.** Es la parte donde se van a desplegar nuestras aplicaciones, tanto las desarrolladas como las adquiridas mediante licencia. Aunque profundizaremos en este grupo más adelante, debemos tener en cuenta que las aplicaciones pueden desplegarse tanto en nuestros entornos físicos como en la nube.
- **Contenedores.** Se trata de entornos dedicados para facilitar los despliegues de nuestras aplicaciones. Presentan numerosas ventajas, ya que son sistemas más livianos y sencillos de desplegar y nos permiten diferenciar entre entornos de la manera más sencilla posible. El contenedor más conocido es docker.

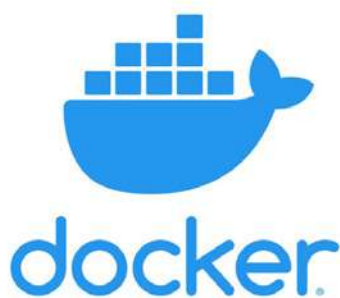


Figura 14. Logo de docker

En base a los tres grupos anteriores, podemos referirnos a una serie de conceptos que se han de considerar a la hora de valorar qué tipo de pruebas se podrían realizar para obtener un análisis del estado en el que se encuentra el *software* con el que estamos trabajando en términos de seguridad:

- **Hacking.** Acción de identificar y explotar las vulnerabilidades de un sistema informático a través de diferentes técnicas. En función de los conocimientos que se posean acerca del sistema y de los objetivos que persiga la persona que lo esté revisando, podemos referirnos a diversos tipos de *hacking*. En el siguiente tema, abordaremos los objetivos de los distintos tipos de *hackers* a los que nos podemos enfrentar.

En cuanto a los conocimientos, se dividen en tres tipos (normalmente, son contratados por la compañía tras firmar un contrato de confidencialidad):

- **Black box.** El *pentester* (es decir, la persona con conocimientos de seguridad que va a realizar la labor de auditar) apenas dispone de información del sistema y simula lo máximo posible el entorno que se va a analizar partiendo de los “mismos” conocimientos que poseería el atacante.
- **White box.** La compañía proporciona al *pentester* los datos del sistema, ciertas estructuras e incluso claves para “facilitar” el análisis. Es el más completo y suele ser el que más información obtiene, pero siempre partiendo de los datos que la empresa ha ofrecido.
- **Grey box.** Se trata de una combinación de los dos tipos anteriores, donde el *pentester* no parte de cero, sino que dispone de determinada información para abordar la auditoría.

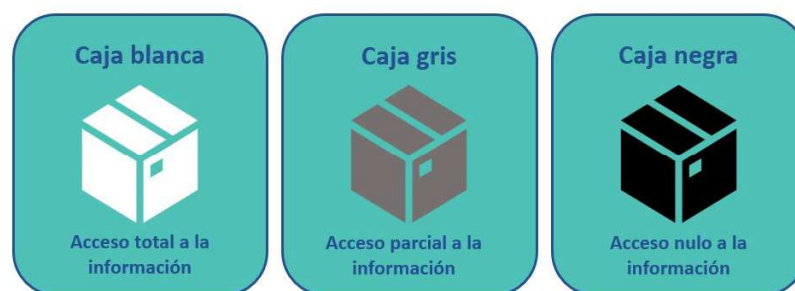


Figura 15. Diferentes tipos de *pentesting*

- **Target.** Es el objetivo del ataque, ya sea una persona, un ordenador o toda una infraestructura, es decir, cualquier sistema que se encuentre detrás de una dirección IP.
- **Bug.** Error no reconocido que se ha detectado en el sistema y que puede producirse de manera aleatoria. El origen de este término, ampliamente adoptado en el ámbito de la informática, se remonta a 1945, cuando se descubrió un insecto en una máquina en Harvard.
- **Exploit.** Código utilizado para aprovecharse de una vulnerabilidad identificada y que “facilita” el ataque al sistema. Existen herramientas que cuentan con una gran cantidad de *exploits* libres para probar las vulnerabilidades de un sistema (teniendo en cuenta que tanto para los *black hat* como para los *white hat* la información pública es la misma).
- **Payload.** Parte del código que realiza la acción maliciosa del *exploit*, como robar una sesión, cifrar una base de datos o conectarse de manera remota a un servidor.
- **Zeroday.** Vulnerabilidad que no ha sido reportada y que, por lo tanto, no es conocida, de modo que si alguien la identifica podría aprovecharse de ella para lograr sus objetivos. Adicionalmente, existe un mercado negro donde conseguir este tipo de ataques, esto es, donde el atacante podría exponer las condiciones del sistema que se quiere atacar para vulnerarlo.

En definitiva, explorando los conceptos de seguridad relativos al *software*, así como los términos relacionados con la seguridad ofensiva, podemos obtener una perspectiva más completa de la importancia que cobra la seguridad en el entorno digital. Mediante un desarrollo seguro del código, una configuración adecuada de los contenedores, la protección de la infraestructura y la conciencia de las amenazas y las técnicas de ataque, se puede fortalecer el sistema y reducir los posibles riesgos.